

Task 4 Data Classification Policy

By Stephen Reilly | *Security Policy Analysis Series*

Objective

Create a Data Classification Policy that defines how data should be categorized and protected based on sensitivity.

Scenario

Company: HealthPlus Medical Group

Industry: Healthcare

Data Types:

- Patient medical records (PHI)
- Employee information (PII)
- Financial data
- Research data
- Business operations data
- Public marketing materials

Compliance Requirements: HIPAA, GDPR, State privacy laws

Classification Levels

Create a policy with these classification levels:

Level	Description	Examples
PUBLIC	Approved for release	Marketing, website
INTERNAL	Internal use only	Memos, org charts
CONFIDENTIAL	Could cause harm	PII, financials
RESTRICTED	Severe damage	PHI, credentials

Requirements

Your policy must define for EACH classification level:

1. Handling Requirements

Requirement	Public	Internal	Confidential	Restricted
Labeling	[Y/N]	[Y/N]	[Y/N]	[Y/N]
Encryption at Rest	[Y/N]	[Y/N]	[Y/N]	[Y/N]
Encryption in Transit	[Y/N]	[Y/N]	[Y/N]	[Y/N]
Access Control	[Type]	[Type]	[Type]	[Type]

Required Sections

1. **Labeling** - headers, file naming
2. **Storage** - approved/prohibited locations

3. **Transmission** - email, file transfer rules
 4. **Disposal** - paper shredding, media sanitization
 5. **Access Control** - who, how, reviews
-

Deliverables

1. Complete Data Classification Policy
2. Quick Reference Guide (1-page summary for employees)

Data Classification Policy

Organization: HealthPlus Medical Group

Document Version: 1.0

Effective Date: June 22, 2026

Review Date: June 22, 2027

Approved By: [Name/Title - e.g., Chief Information Security Officer]

Policy Owner: Cybersecurity Department

Contact for Questions: security@healthplus-medical.com

1. Purpose

The purpose of this policy is to establish a framework for classifying data based on its sensitivity, value, and the potential impact of unauthorized disclosure, modification, or loss. This ensures that HealthPlus Medical Group protects patient privacy, maintains regulatory compliance (HIPAA, GDPR, State Privacy Laws), and secures intellectual property while facilitating appropriate data sharing.

2. Scope

This policy applies to all employees, contractors, consultants, temporary staff, and third-party vendors who access, create, store, transmit, or dispose of HealthPlus Medical Group data. It covers all forms of data, including but not limited to electronic files, paper records, databases, emails, and communications sent via mobile devices.

3. Regulatory Compliance

This classification system is designed to meet the requirements of:

- **HIPAA (Health Insurance Portability and Accountability Act):** Specifically regarding Protected Health Information (PHI).
- **GDPR (General Data Protection Regulation):** Regarding Personally Identifiable Information (PII) of EU citizens.
- **State Privacy Laws:** Including specific state regulations regarding medical data and consumer privacy.

4. Data Classification Levels

Data at HealthPlus Medical Group is categorized into four levels based on sensitivity. All data must be assigned one of these classifications.

4.1 Level Definitions & Handling Requirements

Requirement	PUBLIC	INTERNAL	CONFIDENTIAL	RESTRICTED
Definition	Approved for public release. No harm from disclosure.	Intended for internal use only. Disclosure may cause minor operational inconvenience.	Sensitive data. Disclosure could cause moderate harm to reputation, financial standing, or individuals.	Highly sensitive data. Disclosure could cause severe damage, legal liability, or regulatory fines.
Examples	Marketing brochures, press releases, website content, public job postings.	Organizational charts, internal memos, non-sensitive policies, meeting minutes.	Employee PII (SSN, home address), financial reports, vendor contracts, research drafts.	Patient PHI , login credentials, encryption keys, full social security numbers, unreleased merger plans.
Labeling	No (Optional footer)	Yes (Header/Footer: "Internal Use Only")	Yes (Header/Footer: "Confidential")	Yes (Header/Footer: "RESTRICTED - DO NOT DISTRIBUTE")
Encryption at Rest	No	Optional	Yes	Yes
Encryption in Transit	No	Optional	Yes	Yes
Access Control	Public Access	Role-Based Access (All Employees)	Role-Based Access (Need-to-Know basis)	Strict Need-to-Know (Explicit Authorization Required)
Access Reviews	N/A	Annual	Semi-Annual	Quarterly

5. Detailed Handling Procedures

5.1 Labeling

- **Digital Documents:** Must include the classification level in the document header or footer (e.g., CLASSIFICATION: CONFIDENTIAL). File names should also reflect the classification if possible (e.g., ProjectX_External.pdf vs ProjectX_RESTRICTED.pdf).
- **Emails:** The subject line of emails containing Confidential or Restricted data must include the classification tag (e.g., [CONFIDENTIAL] Budget Review Q3).
- **Physical Documents:** Hard copies of Internal, Confidential, or Restricted data must have the classification stamped or printed clearly on the first page and any summary sheets.

5.2 Storage

- **Approved Locations:**

- **Public/Internal:** Company SharePoint, approved cloud collaboration tools with standard permissions.
- **Confidential:** Encrypted company drives, secure departmental servers with restricted folder access.
- **Restricted:** Isolated, encrypted environments (e.g., specific EHR systems), air-gapped backups, or hardware security modules (HSM) for keys.
- **Prohibited Locations:**
 - Personal cloud storage (Dropbox, Google Drive personal accounts).
 - Unencrypted USB drives or external hard disks.
 - Desktop local folders without disk-level encryption.
 - Home computers unless utilizing an approved Virtual Desktop Infrastructure (VDI).

5.3 Transmission

- **Email:**
 - **Confidential/Restricted:** Must be sent via encrypted email services. If sending to external parties, use secure file transfer portals or password-protected archives (sent via separate channel).
 - **Internal:** Standard internal email is permitted; however, accidental external forwarding should be avoided.
- **File Transfer:**
 - Direct peer-to-peer transfers (FTP without TLS, unencrypted chat apps) are prohibited for Confidential and Restricted data.
 - Use approved Secure File Transfer Protocol (SFTP) or Proton Drive (if configured for enterprise E2EE) for sensitive external sharing.

5.4 Disposal

- **Electronic Data:**
 - **Confidential/Restricted:** Must be sanitized using NIST 800-88 compliant wiping software before reuse or destruction. Hard drives containing Restricted data must be physically destroyed (shredded/crushed) if no longer needed.
 - **Internal:** Secure deletion (logical deletion with overwrite) is sufficient for standard decommissioned drives.
- **Physical Data:**
 - **Confidential/Restricted:** Must be cross-cut shredded or incinerated. No recycling of paper containing Restricted data is permitted.
 - **Internal:** Shredding is recommended; secure bins must be used.

5.5 Access Control

- **Principle:** Access is granted based on the "Least Privilege" principle. Users receive access only to the data necessary to perform their job functions.
- **Authorization:**
 - **Confidential:** Requires manager approval.
 - **Restricted:** Requires explicit written approval from the Data Owner (e.g., Chief Medical Officer, HR Director) and the CISO.
- **Reviews:** Access lists for Restricted data will be audited quarterly by the Cybersecurity team. Any anomalies must be reported immediately.

6. Violations and Enforcement

Failure to comply with this policy may result in disciplinary action, up to and including termination of employment and legal prosecution. Breaches involving Restricted data (PHI) will trigger the Incident Response Plan immediately.

7. Exceptions

Any exceptions to this policy must be documented, justified, and approved by the Chief Information Security Officer (CISO) and the relevant Data Owner. Exceptions are time-limited and subject to annual review.

8. Policy Maintenance

This policy will be reviewed annually or upon significant changes in regulatory requirements (e.g., new state privacy laws). Updates will be communicated to all staff via official company channels.